



**UNIVERSIDAD
TÉCNICA DE
MANABÍ**
Fundada en 1952



UNIVERSIDAD TÉCNICA DE MANABI
FACULTAD DE CIENCIAS INFORMÁTICAS
INGENIERÍA DE SOFTWARE
AUDITORÍA INFORMÁTICA (ING SOFT 2021) -
2026-1

APLICACIÓN DE COSO & COBIT EN LA AUDITORÍA INFORMÁTICA

DOCENTE

ING. DENISE VERA NAVARRETE, MG

INTEGRANTES

ANCHUNDIA FLORES JEFFERSON ALEX

ANZULES ARTEAGA JUAN ANTONIO

ORTEGA PLACENCIO DODY JOE

PORTOVIEJO, 10 JUNIO 2026

METODOLOGÍA DE LA AUDITORÍA SOLICITADA

Fase I: Planificación e Investigación Preliminar

Mapecto de todas las soluciones de IA en uso, autorizadas y no autorizadas (Shadow AI).

Soluciones Autorizadas (Gobierno Corporativo Parcial):

- GitHub Copilot: Integrado en los IDE corporativos para la aceleración de desarrollo.
- ChatGPT Enterprise: Utilizado para la documentación y optimización de algoritmos.
- Generadores de difusión: Herramientas para el diseño de assets visuales por el equipo UX/UI.

Shadow AI (Uso no autorizado detectado):

- **Cuentas Personales de IA (ChatGPT Free, Claude, DeepSeek):** Empleadas de forma independiente por desarrolladores para resolver bugs e introducir fragmentos de código propietario sin anonimizar.

Fase II: Diseño del Programa de Auditoría

Redacción de listas de verificación basadas en los componentes COSO y objetivos de control COBIT.

Lista de Control Interno de Software (COSO)						
Esta herramienta permite evaluar el control interno aplicado al ciclo de vida del software bajo el marco COSO. Complete el 'Checklist' para ver los resu.						
CONTROLES TOTALES		% CUMPLIMIENTO GLOBAL		BRECHAS CRÍTICAS (NO CUMPLE)		
22		38,6%		13		
Análisis por Componente COSO						
Componente COSO	Controles	Cumple	Cumple Parcial	No Cumple	No Aplica	% Nivel de Madurez
1. Entorno de Control	4	1	1	3	0	37,5%
2. Evaluación de Riesgos	3	1	0	2	0	33,3%
3. Actividades de Control	7	2	0	5	0	28,6%
4. Información y Comunicación	4	2	0	2	0	50,0%
5. Supervisión y Monitoreo	4	2	0	2	0	50,0%
TOTAL GENERAL	22	8	1	14	0	39,9%

Link de la Lista de Control Interno de Software:

[https://drive.google.com/drive/folders/1mZVokdqnmmgD1S2_mk979V8kHygmnr-
?usp=sharing](https://drive.google.com/drive/folders/1mZVokdqnmmgD1S2_mk979V8kHygmnr-?usp=sharing)

OBJETIVOS DE CONTROL COBIT.

DOMINIO COBIT	PROCESO ESPECÍFICO	ENFOQUE DE AUDITORÍA PARA IA EN NOVAREB
APO (Alinear, Planificar y Organizar)	APO12 - Gestionar el Riesgo	Evaluar los riesgos emergentes de la IA generativa, definiendo perfiles de riesgo tecnológico actualizados y niveles de tolerancia a fallos algorítmicos.
BAI (Construir, Adquirir e Implementar)	BAI03 - Gestionar la Identificación y Construcción de Soluciones	Auditar el SDLC para verificar que las herramientas de IA (Copilot) cumplan con la validación de código seguro y pruebas estáticas (SAST).
DSS (Entregar, Dar Servicio y Soporte)	DSS05 - Gestionar los Servicios de Seguridad	Controlar los accesos de las API de IA y los mecanismos de DLP (Prevención de Fuga de Datos) para evitar la salida de datos sensibles corporativos.
MEA (Monitorear, Evaluar y Valorar)	MEA01 - Monitorear, Evaluar y Valorar el Rendimiento y la Conformidad	Establecer métricas clave (KPIs) y de riesgo (KRIs) para medir la efectividad de la IA y asegurar el cumplimiento legal europeo e internacional.

Fase III: Pruebas de Cumplimiento y Sustantivas.

Análisis de vulnerabilidades en el código generado, revisión de configuraciones de privacidad en plataformas SaaS de IA, y auditoría de los contratos de proveedores de modelos de lenguaje grande (LLM).

3.1. Pruebas de Cumplimiento (Validación de Políticas y Adherencia)

1. Auditoría de Configuración en Plataformas SaaS (GitHub Copilot / ChatGPT Enterprise):

- Procedimiento: Inspección directa de las consolas de administración central de NovaWeb.
- Objetivo: Verificar si está activada explícitamente la casilla "Permitir que el proveedor use nuestro código para entrenamiento de modelos globales". La política corporativa exige que esté desactivada para mitigar fugas bajo GDPR.

2. Revisión Contractual y de SLA de Proveedores LLM:

- Procedimiento: Análisis legal e informático de los contratos firmados con OpenAI y Microsoft.
- Objetivo: Constatar las cláusulas de propiedad intelectual, indemnizaciones ante demandas por derechos de autor, y políticas de retención de datos en tránsito.

3.2. Pruebas Sustantivas (Validación Técnica del Software y Datos)

1. Análisis Automatizado de Vulnerabilidades en Código Generado (Pruebas SAST/DAST):

- Procedimiento: Ejecución de escaneos estáticos mediante herramientas automáticas sobre los repositorios de código generados en los últimos 3 meses bajo asistencia de IA.
- Objetivo: Identificar de forma cuantitativa la inyección involuntaria de fallos de seguridad críticos del **Top 10 de OWASP** (Inyecciones SQL, dependencias rotas o desactualizadas recomendadas por el efecto de alucinación del modelo).

2. **Auditoría Forense de Logs de Red (Detección de Shadow AI):**

- Procedimiento: Extracción y análisis cruzado de registros de DNS y Firewalls perimetrales apuntando a dominios conocidos de IA de acceso público (ej. chat.openai.com, claude.ai) originados desde segmentos de red de desarrollo.
- Objetivo: Mapear y cuantificar el volumen de fuga potencial de código propietario introducido de forma manual mediante cuentas personales.

PREGUNTAS DE DISCUSIÓN Y ASIGNACIÓN DEL CASO

1. **¿De qué manera el componente de 'Evaluación de Riesgos' de COSO interactúa con el proceso 'APO12 - Gestionar el Riesgo' de COBIT para mitigar la fuga de datos confidenciales por medio de herramientas de IA generativa?**

La interacción entre el componente Evaluación de Riesgos de COSO y el proceso APO12 de COBIT es sinérgica y complementaria, operando en dos niveles distintos pero articulados: el nivel organizacional estratégico (COSO) y el nivel técnico-operativo de TI (COBIT).

MARCO	ENFOQUE	APORTACIÓN ESPECÍFICA PARA MITIGAR FUGA DE DATOS
COSO - Evaluación de Riesgos	Identifica y analiza riesgos a nivel global de la organización, considerando factores internos y externos que puedan afectar el logro de objetivos.	Permite reconocer que el uso de IA generativa representa un riesgo de fuga de propiedad intelectual y datos sensibles, estableciendo la necesidad de políticas de confidencialidad y clasificación de información.
COBIT - APO12 (Gestionar el Riesgo)	Define un proceso específico para identificar, analizar, evaluar, responder y monitorear riesgos relacionados con TI,	Traduce el riesgo estratégico (fuga de datos) en controles técnicos concretos: evaluar qué APIs de IA reciben datos, revisar contratos con proveedores LLM, implementar mecanismos de

	alineados con el apetito de riesgo del negocio.	enmascaramiento de datos (data masking) antes de enviar prompts.
--	---	--

Mecanismo de interacción práctico para mitigar fuga de datos:

1. COSO (Evaluación de Riesgos) detecta que desarrolladores envían código propietario a ChatGPT usando cuentas personales → lo cataloga como riesgo de fuga de información confidencial con impacto alto.
2. Esta información alimenta el proceso APO12 de COBIT, donde el auditor o gestor de riesgos de TI:
 - Realiza un análisis cuantitativo y cualitativo (probabilidad vs impacto)
 - Define respuestas al riesgo:
 - *Mitigar*: implementar DLP (Data Loss Prevention) que bloquee envíos a dominios no autorizados
 - *Evitar*: prohibir cuentas personales y estandarizar cuentas corporativas con políticas de retención cero
 - Establece indicadores de riesgo (KRI) como "número de intentos de envío de datos sensibles a APIs externas por semana"
3. **Retroalimentación:** Los hallazgos técnicos de APO12 (ej. se detectaron 50 eventos de fuga potencial) se reportan al nivel COSO para que la alta dirección reevalúe el apetito de riesgo y ajuste las políticas generales.

CONCLUSIÓN: COSO identifica el *qué* (fuga de datos como riesgo estratégico), mientras que COBIT APO12 define el *cómo* gestionarlo técnicamente. Sin COSO, el riesgo se ignora estratégicamente; sin APO12, no hay controles efectivos para mitigarlo.

2. Diseñar un control específico para el proceso COBIT BAI03 que asegure que el código fuente generado por GitHub Copilot pase por una validación estricta de seguridad antes de su compilación final.

A continuación, se presenta el diseño de un control formal basado en el proceso BAI03 - Gestionar la Identificación y Construcción de Soluciones de COBIT.

ELEMENTO DEL CONTROL		DESCRIPCIÓN
NOMBRE DEL CONTROL	<i>Validación Obligatoria de Código Asistido por IA (VO-IA)</i>	
OBJETIVO DEL CONTROL	Garantizar que todo fragmento de código generado o sugerido por GitHub Copilot sea sometido a un análisis de seguridad estático y dinámico, y aprobado por un revisor humano, antes de su integración a la rama principal (main/master) y compilación final.	
ALCANCE	Todos los desarrolladores que utilicen GitHub Copilot en los proyectos de NovaWeb Solutions S.A.	
TIPO DE CONTROL	Preventivo (bloquea la integración) y Detective (genera alertas)	

PROCEDIMIENTO DETALLADO DEL CONTROL

Paso 1: Identificación del código generado por IA

Se configura un hook en el sistema de control de versiones (Git) que etiquete automáticamente los commits o líneas de código que provengan de sugerencias de GitHub Copilot (mediante análisis de metadatos del IDE o plugins específicos).

Paso 2: Análisis estático de seguridad (SAST) obligatorio

Antes de permitir la creación de un pull request (PR), el código etiquetado como "asistido por IA" debe pasar por una herramienta SAST (ej. SonarQube, Checkmarx) configurada con reglas OWASP Top 10.

Criterio de éxito: El código no debe contener vulnerabilidades de severidad alta o crítica (inyección SQL, XSS, autenticación rota, uso de bibliotecas obsoletas o inexistentes).

Paso 3: Revisión humana obligatoria (Human-in-the-loop)

Si el SAST es exitoso, el código pasa a un revisor humano obligatorio (desarrollador senior o líder técnico) que no haya participado en la generación asistida.

El revisor debe verificar:

- Coherencia lógica (ausencia de alucinaciones)
- Ausencia de secretos o credenciales embebidas
- Cumplimiento de estándares de codificación interna

Paso 4: Bloqueo de compilación

El pipeline de CI/CD (ej. GitHub Actions, Jenkins) se configura para no ejecutar la compilación final ni el despliegue a entornos de prueba si no se completan los pasos 1, 2 y 3.

Se genera un reporte automático que documenta:

- Fragmento de código generado por IA
- Resultados del SAST
- Nombre del revisor humano y fecha de aprobación

Paso 5 - Trazabilidad y evidencia de auditoría

Toda la evidencia (logs de SAST, aprobaciones del revisor, metadata de Copilot) se almacena en un repositorio central inmutables durante al menos 12 meses para fines de auditoría.

3. Si usted fuera el auditor líder, ¿qué métricas de cumplimiento (KPI) y qué indicadores clave de riesgo (KRI) propondría en el dominio MEA de COBIT para medir el nivel de seguridad y ética en el uso corporativo de la Inteligencia Artificial?

Como un auditor líder, propongo las siguientes métricas alineadas con el proceso MEA01 - Monitorear, Evaluar y Valorar el Rendimiento y la Conformidad de COBIT, distinguiendo entre KPIs (miden rendimiento/efectividad de los controles) y KRIs (alertan sobre exposición a riesgos).

INDICADORES DE RENDIMIENTO (KPI) - SEGURIDAD Y ÉTICA EN IA

KPI	FÓRMULA DE CÁLCULO	META	FRECUENCIA	PROPÓSITO
% de código generado por IA revisado por humano	$(\text{Commits IA revisados} / \text{Total commits IA}) \times 100$	$\geq 98\%$	Semanal	Medir cumplimiento del control BAI03
Tasa de vulnerabilidades bloqueadas por SAST	$(\text{Vuln. detectadas por SAST} / \text{Total sugerencias IA}) \times 100$	$\geq 85\%$	Quincenal	Efectividad de la validación automática
% de empleados capacitados en uso ético y seguro de IA	$(\text{Empleados capacitados} / \text{Total desarrolladores y científicos de datos}) \times 100$	100% en 3 meses	Mensual	Medir cultura de control interno (COSO)
Tiempo medio de respuesta ante alerta de fuga de datos	Suma de tiempos de respuesta / Número de incidentes	< 2 horas	Mensual	Capacidad de reacción ante eventos críticos

% de prompts anonimizados antes de enviarse a APIs externas	(Prompts con datos enmascarados / Total prompts) × 100	100%	Diario	Cumplimiento de GDPR y privacidad
--	--	------	--------	-----------------------------------

INDICADORES CLAVE DE RIESGO (KRI) - SEGURIDAD Y ÉTICA EN IA

KRI	FÓRMULA DE CÁLCULO	UMBRAL DE ALERTA (ROJO)	FRECUENCIA	SEÑAL DE RIESGO
Frecuencia de intentos de fuga de datos sensibles	Número de eventos DLP bloqueados por semana	> 10 eventos/semana	Diaria	Empleados enviando PII o código propietario a IA externa
% de prompts que contienen información personal identificable (PII)	(Prompts con PII / Total prompts monitoreados) × 100	> 3%	Semanal	Riesgo de incumplimiento GDPR
Número de bibliotecas obsoletas o inexistentes sugeridas por IA e implementadas	Conteo de casos detectados en revisión post-compilación	> 5 por sprint	Por sprint (2 semanas)	Riesgo de alucinaciones y vulnerabilidades críticas

Tasa de quejas por sesgo o falta de accesibilidad en interfaces generadas por IA	(Quejas documentadas / Total releases) × 100	> 5%	Mensual	Riesgo reputacional y ético
Proporción de uso de cuentas personales vs cuentas corporativas en herramientas de IA	(Prompts desde cuentas personales / Total prompts) × 100	> 10%	Semanal	Shadow IA - pérdida de control y trazabilidad

4. Elaborar un dictamen de auditoría preliminar (en base a una escala de madurez de procesos del 0 al 5 según COBIT) determinando en qué nivel se encuentra NOVAREB SOLUTIONS si se considera que usan la IA de manera generalizada, pero sin políticas formales de gobierno.

ESCALA DE MADUREZ COBIT UTILIZADA (0 A 5)

NIVEL	DENOMINACIÓN	DESCRIPCIÓN
0	Inexistente	No se aplican procesos. No se reconoce el riesgo.
1	Inicial / Ad hoc	Procesos informales, sin documentación. Se actúa reactivamente.
2	Repetible pero intuitivo	Se repiten algunas prácticas, pero sin estandarización formal.
3	Proceso definido	Procedimientos estandarizados, documentados y comunicados.

4	Gestionado y medible	Se monitorean KPIs/KRIs y se corrigen desviaciones.
5	Optimizado	Mejora continua basada en datos y retroalimentación.

EVALUACIÓN POR PROCESO COBIT RELEVANTE

Proceso COBIT	Nivel de madurez	Justificación
APO12 - Gestionar el Riesgo	1	Se reconoce el riesgo de fuga de datos y alucinaciones (conciencia inicial), pero no existe una matriz de riesgos formal para IA. No hay evaluación cuantitativa ni respuesta planificada.
BAI03 - Construir soluciones	1.5	Los desarrolladores usan GitHub Copilot de manera generalizada, pero no hay controles obligatorios (SAST o revisión humana). Existen prácticas aisladas no formalizadas.
DSS05 - Servicios de Seguridad	1	No hay DLP configurado para APIs de IA. Se detectó uso de cuentas personales. La seguridad es reactiva.
MEA01 - Monitoreo y evaluación	0	No existen KPIs/KRIs para IA. No hay dashboard, métricas de cumplimiento ni auditorías periódicas. El monitoreo es nulo.

NIVEL DE MADUREZ INTEGRADO GLOBAL

NIVEL 1.1 - INICIAL / AD HOC

FUNDAMENTO DEL DICTAMEN:

NOVAWEB SOLUTIONS S.A. presenta una situación paradójica:

- **Fortaleza:** Existe una adopción masiva y exitosa de IA generativa (incremento del 40% en velocidad de entrega).
- **Debilidad crítica:** Esta adopción ocurre sin políticas formales, controles técnicos ni métricas de gobierno.

La organización se encuentra en una fase reactiva: los riesgos son conocidos por la junta directiva, pero aún no se han traducido en acciones concretas. El uso de cuentas personales, la ausencia de revisión humana obligatoria y la falta de monitoreo colocan a NOVAWEB en el nivel 1 (Inicial), con algunas prácticas repetitivas no documentadas que justifican un 1.1.

CARACTERÍSTICAS OBSERVADAS DE NIVEL 1:

- ✓ Existe conciencia del riesgo a nivel directivo
- ✓ La IA se usa de manera generalizada
- ✗ No hay políticas ni procedimientos documentados
- ✗ No hay controles automáticos (SAST obligatorio, DLP)
- ✗ No hay métricas ni monitoreo
- ✗ No hay roles ni responsabilidades formalizados para supervisión de IA
- ✗ La capacitación es inexistente o informal

RECOMENDACIONES PARA ALCANZAR NIVEL 3 EN 12 MESES

PRIORIDAD	ACCIÓN	PROCESO COBIT	NIVEL OBJETIVO	PLAZO
1	Crear e implementar política formal de uso de IA generativa (cuentas corporativas, datos permitidos, revisión humana)	APO12, BAI03	2 → 3	3 meses
2	Implementar DLP y bloqueo de cuentas personales	DSS05	1 → 3	2 meses
3	Configurar SAST obligatorio en pipeline CI/CD para código generado por IA	BAI03	1.5 → 3	4 meses
4	Establecer DASHBOARD con KPIs/KRIs y revisión mensual por el Comité de Ética en IA	MEA01	0 → 2	6 meses
5	Capacitar al 100% de los desarrolladores en uso seguro y ético de IA	APO12	1 → 3	3 meses